

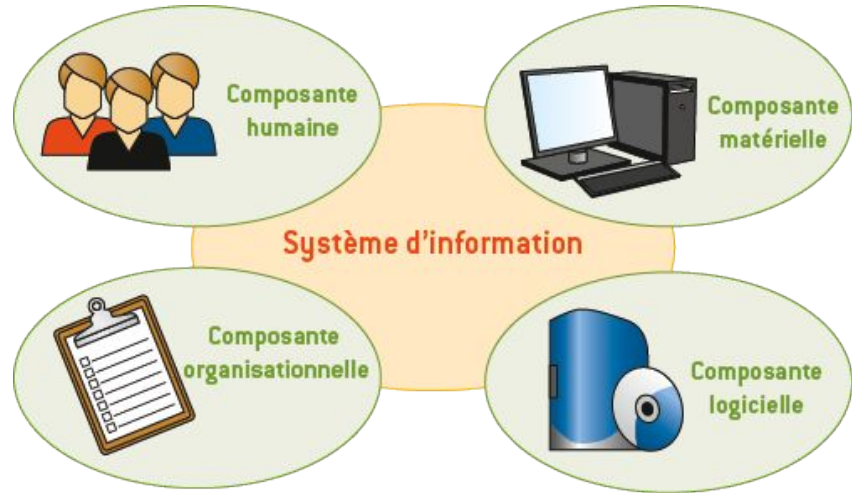
Audit SSI

Chapitre 1 : Fondamentaux des systèmes d'information et de leur sécurité

Définition et rôle d'un système d'information (SI)

Un **Système d'Information** (SI) désigne l'ensemble organisé de **ressources** (humaines, techniques, logicielles, organisationnelles) permettant de **collecter, traiter, stocker, sécuriser, et diffuser l'information** au sein d'une organisation.

Il supporte les processus métiers, facilite la prise de décision, et assure la continuité des opérations.



Définition et rôle d'un système d'information (SI)

Composants d'un SI :

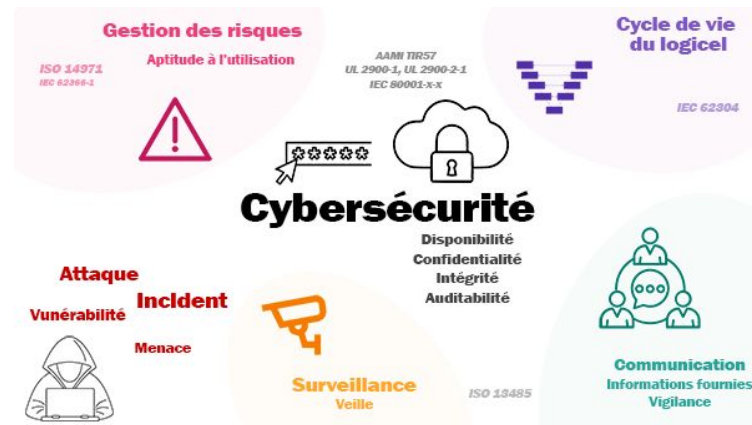
1. **Composantes humaines** : utilisateurs, administrateurs, DSI, RSSI.
2. **Composantes matérielles** : ordinateurs, serveurs, routeurs, pare-feux, terminaux mobiles.
3. **Composantes logicielles** : systèmes d'exploitation, ERP, CRM, applications métiers.
4. **Composantes données** : bases de données, fichiers, flux de données.
5. **Composantes procédurales** : politiques, procédures, processus de gestion.

Enjeux de la sécurité des SI

La sécurité des SI vise à **protéger les actifs informationnels** contre des menaces variées, tout en assurant leur **bon fonctionnement**.

Elle est **stratégique** pour toute organisation, car une faille peut impacter :

- La **réputation** de l'entreprise.
- La **continuité des activités**.
- La **conformité légale et réglementaire**.
- La **confiance des parties prenantes**.



Enjeux de la sécurité des SI

Enjeux clés :

- **Protection des données sensibles et confidentielles.**
- **Prévention des pertes financières** dues aux cyberattaques.
- **Respect des exigences réglementaires** (RGPD, ISO 27001, PCI-DSS...).
- **Maintien de la performance opérationnelle.**



Principes fondamentaux de la sécurité de l'information

La **sécurité des systèmes d'information** vise à **protéger les données sensibles** des entreprises contre toute **divulgation, modification non autorisée ou indisponibilité**.

Dans un contexte d'**interconnexion accrue** avec les filiales, partenaires et clients, elle garantit un **fonctionnement fiable** du SI.



Principes fondamentaux de la sécurité de l'information

La **sécurité de l'information** englobe un ensemble de mesures techniques, organisationnelles, juridiques et humaines visant à protéger les informations.



Principes fondamentaux de la sécurité de l'information

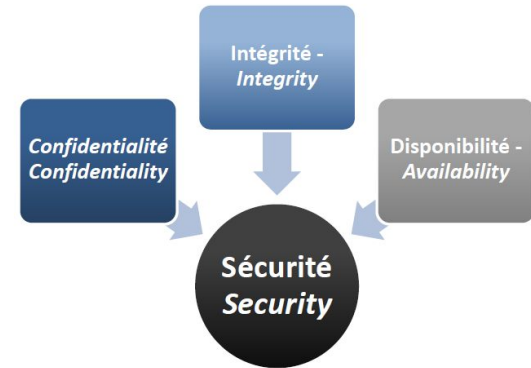
La sécurité repose sur 4 **principes fondamentaux**, souvent désignés par le sigle **CIDT**.

Elle garantit les principes suivants :

Confidentialité, Intégrité, Disponibilité et Traçabilité

Concept clef de voute:

En maitrisant ces concepts vous ferez la différence et vous augmenterez signification vos chances de réussir une mission d'audit.



Principes fondamentaux de la sécurité de l'information

Confidentialité

Seules les **personnes autorisées** peuvent accéder aux informations.

La capacité de **cacher l'information** aux personnes non autorisées

La capacité de garantir que le niveau de secret nécessaire est appliqué

La prévention de la révélation non autorisée de l'information



Principes fondamentaux de la sécurité de l'information

Intégrité

Les informations restent **exactes et complètes**, et ne peuvent être modifiées que par des personnes habilitées.

Garantit que:

Des utilisateurs ou des processus non autorisés ne peuvent modifier les données

Les données sont cohérentes à l'interne et à l'externe

Des utilisateurs ou des processus autorisés ne peuvent faire des modifications non autorisées aux données



Principes fondamentaux de la sécurité de l'information

Disponibilité

Les informations doivent être **accessibles** à ceux qui en ont besoin, quand elles en ont besoin (par exemple, 24h/24).

La capacité de garantir à **tout moment** un accès **fiable** à **l'information**



A quoi bon si les données confidentielles et intègres si on ne peut y accéder ?

Assure: un service et une productivité ininterrompus (même en mode dégradé).

Principes fondamentaux de la sécurité de l'information

Traçabilité

Les accès et tentatives d'accès sont **enregistrés**, assurant un suivi complet et exploitable des actions sur les informations.

Le message d'erreur généré par le processus d'autorisation doit être inscrit dans les journaux d'événements ou fichiers de log.

Toute action, qu'elle soit autorisée ou non doivent être systématiquement être présent dans le journal d'événement. Ceci pour différentes raisons mais le plus significatif est l'investigation.



Autres principes:

IAAA: IDENTITY, AUTHENTICATION, AUTHORIZATION AND ACCOUNTING

Cet ensemble de concepts est souvent voir toujours référé par l'acronyme AAA dans plus revue de la sécurité des systèmes d'information

Identity, Identité / Identification : C'est qui on prétend être. Lorsque vous tapez votre @ dans le champ **userName** d'un site marchand, vous faites clamer votre identité. L'identité est la première étape dans le processus pour accéder à des données.

Authentication : L'authentification en revanche est un e mécanisme qui va prouver que la personne qui à clamé son identité est bien elle. Le cas le plus courant est le mot de passe qui associé au **userName**.

Autres principes:

IAAA: IDENTITY, AUTHENTICATION, AUTHORIZATION AND ACCOUNTING

Autorisation / Autorisation / Habilitation : Vous avez saisis votre user Name et votre mot de passe mais vous n'êtes pas inscrit dans les tables de la base de données. Alors vous êtes identifiés et authentifiés mais pas autorisé. Si l'administrateur a bien fait son travail vous aurez alors un message d'erreur.

Accounting / Preuve : Le message d'erreur généré par le processus d'autorisation doit être inscrit dans les journaux d'événements ou fichiers de log. Toute action, qu'elle soit autorisée ou non doivent être systématiquement être présent dans le journal d'événement. Ceci pour différentes raisons mais le plus significatif est l'investigation.

Autres principes:

Non répudiation : La non répudiation est le fait qu'une personne ne peut pas nier avoir fait une action. Pour être effective, elle a besoin de l'identification, de l'authentification et de l'intégrité et ce, en même temps.

C'est le principe de la signature digitale

Least privilège: C'est le fait de donner le moindre privilège à une ressource. La ressource peut être une personne, un logiciel, un service qui tourne au sein d'un OS.

Need to Know: Est un concept plus granulaire que le précédent concept. Il est lié à un contexte. Il s'applique à une personne en particulier. C'est une information précise qu'une personne doit connaître pour faire son travail.

Typologie des menaces, attaques et vulnérabilités

Définitions :

- **Menace** : tout événement ou agent susceptible de causer un dommage (humain, naturel, technique...).
- **Vulnérabilité** : une faille ou faiblesse exploitable dans un système.
- **Attaque** : action exploitant une ou plusieurs vulnérabilités dans un but malveillant.

Typologie des menaces, attaques et vulnérabilités

Typologie des menaces :

- **Humaines internes** : erreurs, négligences, sabotage.
- **Humaines externes** : cybercriminels, hacktivistes, États-nations.
- **Techniques** : pannes, bugs, obsolescence.
- **Naturelles** : incendie, inondation, séisme.

Typologie des menaces, attaques et vulnérabilités

Sources de vulnérabilités :

- **Logiciels non à jour.**
- **Mots de passe faibles.**
- **Absence de pare-feu ou antivirus.**
- **Mauvaise configuration réseau.**
- **Accès excessifs ou non contrôlés.**

Conclusion

- Dans ce premier chapitre, nous avons posé les bases indispensables à la compréhension de l'audit de la sécurité des systèmes d'information.
- Nous avons vu que le système d'information constitue une ressource stratégique pour toute organisation, au service de ses processus métiers, de sa performance et de sa pérennité.
- Or, dans un contexte où les menaces numériques sont en constante évolution, assurer la sécurité du SI devient un enjeu majeur, tant sur les plans techniques, organisationnels que réglementaires.

Conclusion

- Les principes fondamentaux de sécurité (confidentialité, intégrité, disponibilité, traçabilité) doivent guider toutes les actions de protection du SI.
- La connaissance des menaces, des vulnérabilités et des attaques est essentielle pour bâtir des politiques de sécurité efficaces.